

Silvia Sisinni

silvia.sisinni@polito.it



Module A – Cybersecurity Fundamentals

A4 – Information Protection: Privacy, Data protection,

Secrecy



**Politecnico
di Torino**

Department of Control and
Computer Engineering



TORSEC

Computer and Network Security Group



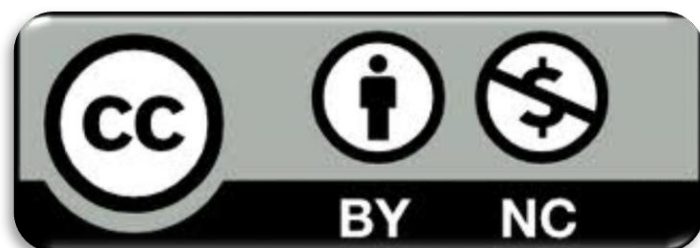
Acknowledgments

This lecture deck *adapts* and *reorganizes* selected teaching material originally developed by Nicolò Maunero (CINI / Cybersecurity National Lab). Portions of the content are reused under the Creative Commons BY-NC license (see license slide). All modifications, additions, re-organization, and any errors are the responsibility of the course instructor.

License & Disclaimer

License Information

This presentation is licensed under the
Creative Commons BY-NC License



To view a copy of the license, visit:

<http://creativecommons.org/licenses/by-nc/3.0/legalcode>

Disclaimer

- We disclaim any warranties or representations as to the accuracy or completeness of this material.
- Materials are provided “as is” without warranty of any kind, either express or implied, including without limitation, warranties of merchantability, fitness for a particular purpose, and non-infringement.
- Under no circumstances shall we be liable for any loss, damage, liability or expense incurred or suffered which is claimed to have resulted from use of this material.
- This material is used and adapted within the course “Cybersecurity and National Defense”.



From Security Properties to Information Protection

- In **Lecture A3** we studied *how* to protect information
 - security properties such as confidentiality, integrity, and availability, accountability, authenticity
 - mechanisms to enforce security properties like like encryption, authentication, and access control
- In **Lecture A4** we study *why, for whom, and under which constraints* information must be protected.



Learning goals

By the end of this lecture, you will be able to:

1. **Differentiate** privacy, data protection, and secrecy
2. **Explain** how data protection constrains system design
3. **Interpret** GDPR principles from an engineering perspective
4. **Understand** the role of secrecy in national defense



Roadmap – From Concepts to National Security

1. Information Protection

- Privacy – Data Protection – Secrecy

2. Data Protection Framework

- GDPR Principles – Accountability – Breach

3. Protection Mechanisms

- Access Control – Encryption – Anonymization – Logging

4. Secrecy & National Defense

- Classification – Need-to-Know – Governance



Information Protection – Three Dimensions



In Information Protection, we usually distinguish between:

- *Privacy*
- *Secrecy*
- *Data Protection*



Privacy as a Fundamental Right



Privacy refers to the protection of an individual's:

- **Private sphere** (personal life and autonomy)
- **Communications** (correspondence and interactions)
- **Behavioural patterns** (habits, preferences, profiling)
- **Identity construction** (freedom from unjustified surveillance)

📌 **Privacy protects the person, not just the data.**



How Privacy Protection is Operationalized

Privacy protection typically requires:

➤ **Data minimization**

- Collect only the data strictly necessary for a defined purpose

➤ **Purpose limitation**

- Use data only for the purpose originally specified

➤ **Informed consent**

- Ensure individuals understand and agree to how their data is used

➤ **Control over access and disclosure**

- Restrict who can access or share personal information

➤ **Limitations on retention**

- Retain data only for as long as necessary



Privacy requires mechanisms, not just intentions.



GARANTE
PER LA PROTEZIONE
DEI DATI PERSONALI



Politecnico
di Torino
Department of Control and
Computer Engineering



- According to the GPDP, in Italy, **privacy protection** covers two fundamental aspects:
 - Right to prevent third parties from accessing what I perceive as "mine"
 - Right to "personal identity," i.e., the right to the integrity and accuracy of my data when they are processed by others, in order to always ensure a *complete* view of my personality



Role of Technology

- Technology enables:
 - **large-scale data collection**
 - **large-scale inference** (i.e., the process of using massive datasets and automated analysis to deduce additional information that was not explicitly provided)
 - **automated profiling** (i.e., the automatic creation of a profile about a person by analyzing their data, in order to evaluate or predict aspects such as behavior, preferences, reliability, or risk)
 - **mass surveillance** (i.e., the large-scale monitoring of people's communications, activities, or movements, often carried out systematically and affecting many individuals at once, not just specific suspects)
- But, it also enables: **encryption, access control, privacy-enhancing technologies** (e.g., Trusted Execution Environments (TEEs))
- Technology must protect user privacy from attacks brought by **technology itself**

Robot vacuum example

L'aspirapolvere robot nel mirino dell'Ue: "Raccoglie dati e scatta foto, privacy a rischio". Sarà proprietà di Amazon

di Aldo Fontanarosa



La Commissione europea invia una serie di domande al gigante del commercio elettronico, che ha comprato il produttore del dispositivo per 1,7 miliardi di dollari. La difesa: tante altre macchine simili disponibili nel mondo, riservatezza garantita

Ascolta l'articolo

03:14





When Smart Homes Become Surveillance Targets

DIEGO BARBERA

SECURITY 09.03.2026

Dji paga 30mila dollari all'informatico che ha hackerato per caso 7000 robot aspirapolvere

Il produttore cinese premia con una ricompensa l'utente francese che ha scoperto una grave falla di sicurezza



PHOTO BY MARK PERNA



Information Protection – Three Dimensions



In Information Protection, we usually distinguish between:

- *Privacy*
- *Secrecy*
- *Data Protection*



Secrecy – Definition

Secrecy concerns the protection of sensitive institutional or state information.

- **What it protects:** sensitive institutional or state information
- **Why it exists:** to *prevent harm that may result from disclosure*
- **Who defines the rules:** institutional authority, mission needs, and public-interest requirements

✦ Unlike privacy, secrecy is centered on **protecting strategic information**, not the individual's private sphere.



Information Protection – Three Dimensions



In Information Protection, we usually distinguish between:

- *Privacy*
- *Secrecy*
- *Data Protection*



Digital Dimension

- In the digital dimension (cyberspace), **personal data** represent and define us as citizens, voters, workers, consumers
- Digital systems generate:
 - **Explicit data** (what we intentionally share)
 - **Implicit data**, i.e., , information generated as a product of interaction (metadata, logs, device fingerprints, click patterns, timing, location traces)
 - **Derived data** (inferences and profiling)
- Risk arises from:
 - Data aggregation
 - Cross-dataset correlation
 - Predictive analytics



Accessible $\neq$ Public $\neq$ Legitimately Usable

- **Accessible:** technically reachable
- **Public:** intentionally disclosed
- **Legitimately usable:** allowed by law and purpose

Example: “publicly accessible” $\neq$ “OK to scrape, merge, and profile”

📌 **Availability $\neq$ authorization** (lawful basis + purpose matter).

Platform Power: Asymmetric Knowledge

- Digital platforms know us much better than we know ourselves
 - **Aggregate** data across services and devices
 - **Predict** preferences, vulnerabilities, and intentions (profiling)
 - **Influence** choices via ranking, nudging, and targeting
- **This creates power** asymmetries that data protection tries to constrain.

<https://www.youtube.com/watch?v=F7pYHN9iC9I>





The Privacy Paradox

- People say “*I value privacy*”, but in practice ...
 - Accept default settings
 - Click “Agree” to access services quickly
 - Share more data than intended
- Why this happens
 - **Information asymmetry**: users don’t know what is collected / inferred
 - **Bounded rationality**: costs are immediate, privacy harms are delayed/uncertain
 - **Dark patterns**: interfaces steer choices (friction to refuse, nudges to accept)
 - $\Rightarrow$ Consent becomes **low-quality** $\rightarrow$ weak signal of real preferences



Giving up personal data in exchange for free services
means giving up the right to self-determination!!
If a service is free, the price is you and your data!!



Roadmap – From Concepts to National Security

1. Information Protection

- Privacy – Data Protection – Secrecy

2. Data Protection Framework

- GDPR Principles – Accountability – Data Breach

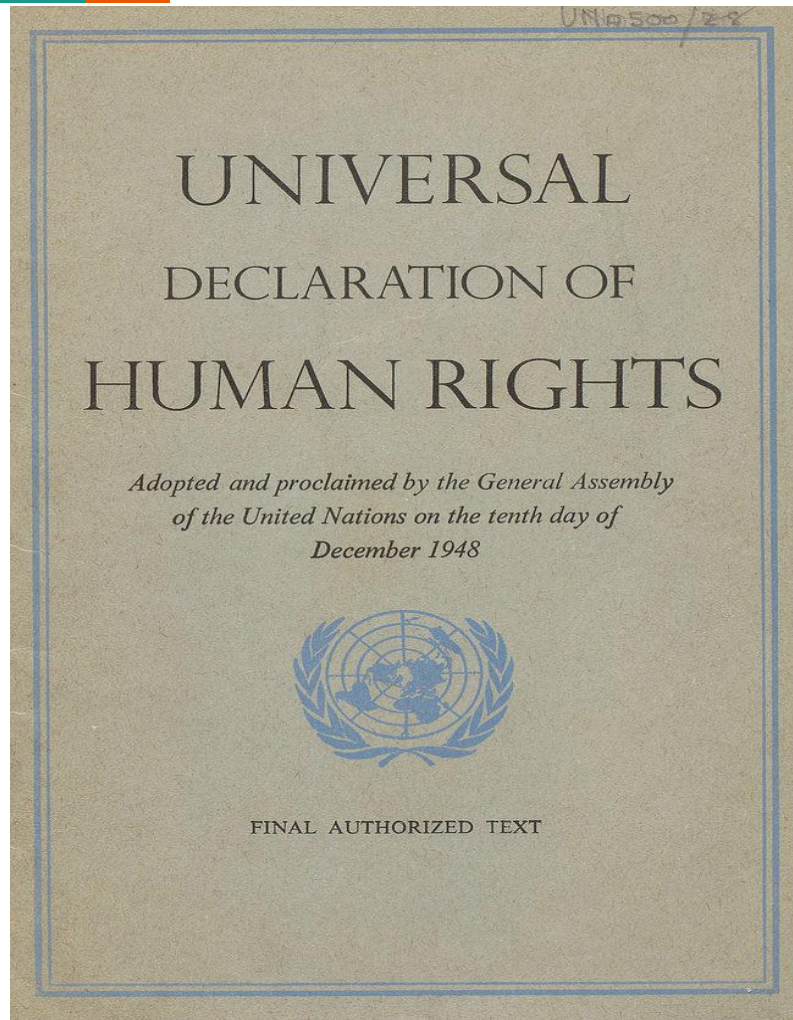
3. Protection Mechanisms

- Access Control – Encryption – Anonymization – Logging

4. Secrecy & National Defense

- Classification – Need-to-Know – Governance

Regulatory framework



12th article:

“No one shall be subjected to arbitrary interference with his privacy, family, home or correspondence, nor to attacks upon his honour and reputation. Everyone has the right to the protection of the law against such interference or attacks”

- From fundamental rights → to enforceable rules for data processing (GDPR).

European Regulatory Framework



As of May 25, 2018, EU Regulation 2016/679, known as GDPR (General Data Protection Regulation) - on the protection of individuals with regard to the processing and free movement of personal data - is directly applicable in all Member States' legal systems.

- GDPR (EU 2016/679) regulates **processing of personal data** across the EU
- Goal: harmonization + protection in the digital economy
- Key idea: **accountability** (organizations must prove compliance)
- Security becomes a **design constraint**, not an optional add-on

*Failure to take
security
measures results
in
liability on a civil
and criminal level*



Charter of Fundamental Rights of the EU

7th article:

Respect for private and family life

- Everyone has the right to **respect** for his or her **private and family life, home and communications**.

8th article:

Protection of personal data

1. Everyone has the right to the protection of personal data concerning him or her.
2. Such **data must be processed fairly for specified purposes** and **on the basis of the consent** of the person concerned **or some other legitimate basis** laid down by law. Everyone has the **right of access** to data which has been collected concerning him or her, and the **right to have it rectified**.
3. Compliance with these rules shall be subject to **control by an independent authority**.



From Principles to Organizational Duties

GDPR principles become concrete duties in the design and operation of information systems.

1. **Lawful basis and purpose definition:** Personal data must be collected for a clear and legitimate purpose
2. **Data minimization and retention limits:** Collect only what is necessary and keep it only as long as needed
3. **Access control and protection measures:** Organizations must restrict access and secure data in storage and transit
4. **Transparency and data-subject rights:** Users must be informed and able to access, correct, or erase their data where applicable
5. **Documentation and incident readiness:** Compliance must be demonstrable, and breaches must be detected, assessed, and managed



Data breach



- *Security breach that accidentally or unlawfully results in the destruction, loss, modification, unauthorized disclosure of or access to personal data transmitted, stored, or otherwise processed.*

[ISO/IEC 27040:2015]

Data breaches can affect:

- **Confidentiality** (unauthorized disclosure/access): e.g., leaked database
- **Integrity** (unauthorized modification): e.g., tampered medical record
- **Availability** (loss/destruction/unavailability): e.g., ransomware encryption



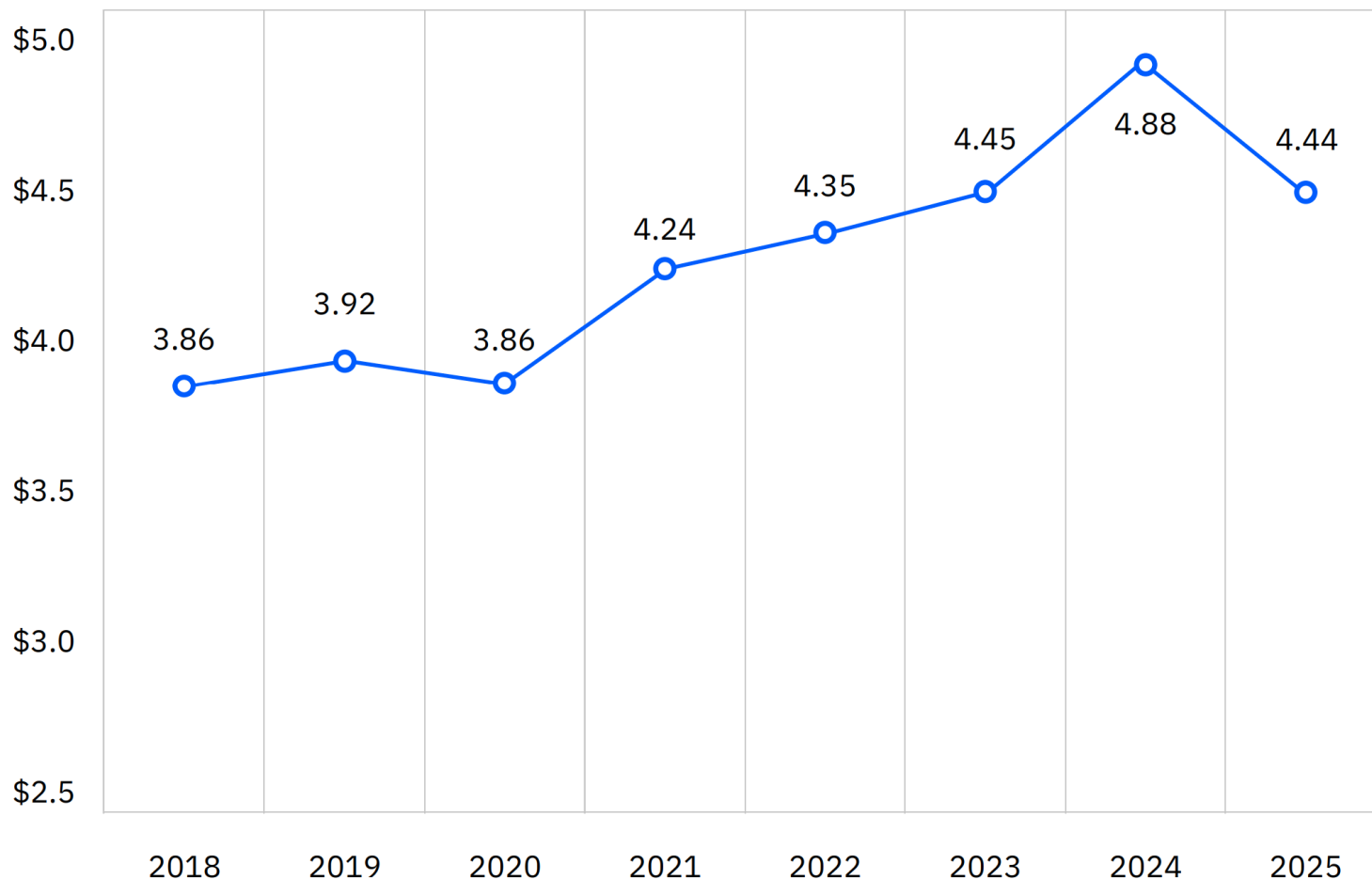
Economic / operational impact of data breaches

- Breaches generate:
 - **direct costs** (incident response, forensics, legal, recovery)
 - and **indirect costs** (downtime, loss of trust, lost business)
- Impact depends on **sector, sensitivity of the data, detection time, and response readiness**
- Reports consistently show **multi-million** average impact for large organizations
 - IBM Security, in its latest report “Cost of a Data Breach Report – 2025” analyzed the global financial impact of a data breach, with an average cost well over \$4 million

[<https://www.ibm.com/reports/data-breach>]

IBM “Cost of a Data Breach Report – 2025”

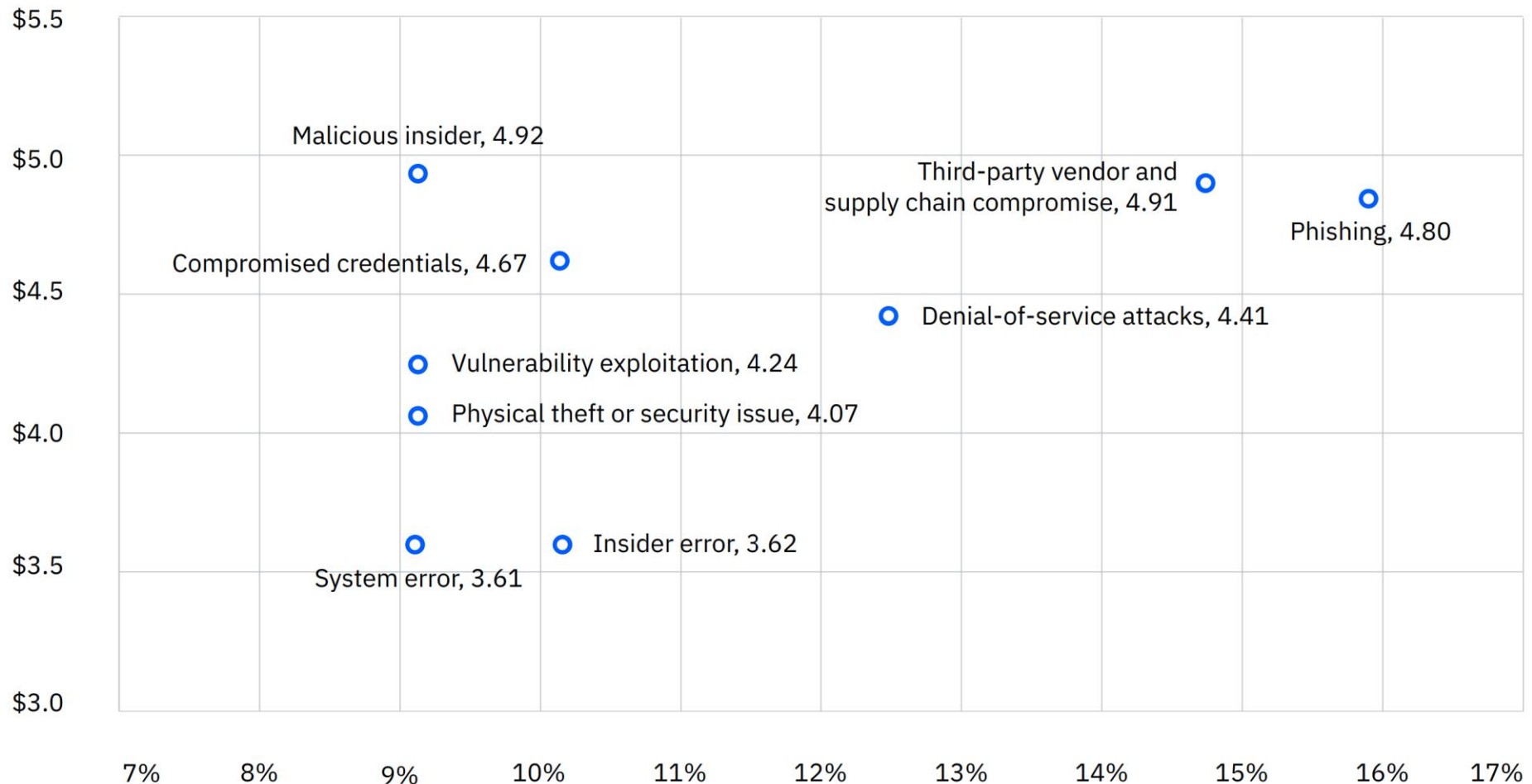
Figure 1.
Measured in USD millions





IBM “Cost of a Data Breach Report – 2025”

Figure 9.
Measured in USD millions; percentage of all breaches





Roadmap – From Concepts to National Security

1. Information Protection

- Privacy – Data Protection – Secrecy

2. Data Protection Framework

- GDPR Principles – Accountability – Data Breach

3. Protection Mechanisms

- Access Control – Encryption – Anonymization – Pseudoanonymization
– Logging

4. Secrecy & National Defense

- Classification – Need-to-Know – Governance



Mechanisms for Information Protection

➤ *Access Control*

Restricts who can access which data and under what conditions.

➤ *Encryption*

Protects data by transforming it into unreadable form without a cryptographic key.

➤ *Anonymization*

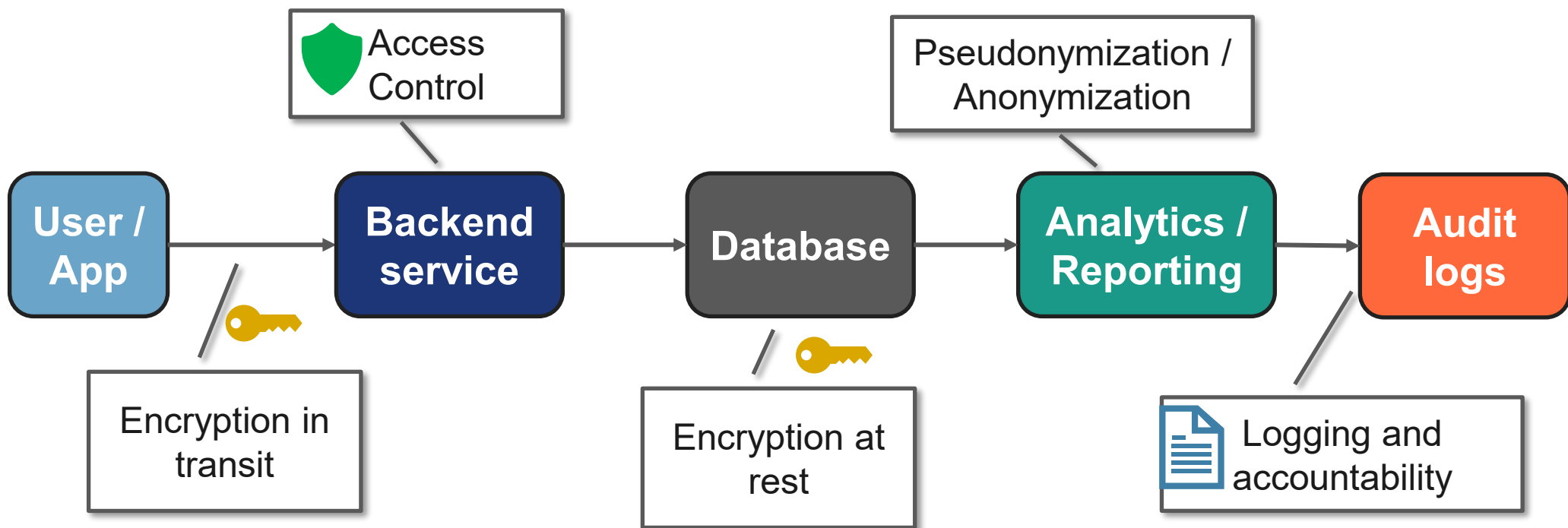
Reduces identifiability of individuals in datasets (i.e., an organized collection of related data, usually stored in a structured way so it can be searched, analyzed, or processed).

➤ *Pseudonymization*

Replaces identifiers with reversible tokens to reduce risk.

How These Mechanisms Work Together

Different controls protect different stages of the same data lifecycle.



- Privacy and data protection are usually achieved through layered controls, not a single mechanism.



Access Control



Access control is the process of granting or denying requests to:

- *Access information resources*
- *Use information processing services*
- *Enter physical or logical domains*

It enforces:

- **Authentication** → Who you are
- **Authorization** → What you can do
- **Accountability** → What you did

[CNSSI 4009-2015 (FIPS 201-1 - Adapted)]



Encryption

- Encryption transforms data into ciphertext using a cryptographic key.
- **Used for:**
 - data at rest (disks, databases, or backups)
 - data in transit (network communication)
- **Security objective:**
 - protect confidentiality even if storage or transmission channels are compromised.
- Encryption protects data, but does not regulate how it is used once decrypted
 - **encryption $\neq$ privacy**



Logging and Accountability

- Logging is often realized through **event records automatically generated and stored by systems**, most commonly:
 - stored as log files on servers, applications, databases, and operating systems
 - structured as audit trails for user and administrator actions
 - collected in centralized logging platforms from multiple sources
- Logging records events related to: access to data, data modification, system activity
- It enables **traceability**, allows to **detect anomalies**, support **incident investigation**
 - GDPR compliance and breach detection support
- **Logging is a detective control**, not a preventive control.



Anonymization



- *Technique applied to personal data in such a way that the individuals concerned can no longer be identified in any way.*

Key characteristics:

- **Removes** or alters **direct identifiers**
 - **Reduces linkability**
 - Requires **contextual risk assessment**
-
- The effectiveness of anonymization also depends on the surrounding environment: what other data exist, what auxiliary information is available, what kinds of correlation are possible



Anonymization

- **Goal:** Eliminate the correlation between personal data and the individual they refer to, making it impossible to identify that person.
- **Consequence:** By the time personal data referring to an individual has been properly anonymized, it should be impossible to reverse the process.
- **GDPR:** If the anonymization has been properly implemented, the data are no longer classified as personal data and therefore do not fall under the application dimension of the GDPR.



Pseudonymization



- *The processing of personal data in such a manner that the **personal data can no longer be attributed to a specific data subject without the use of additional information**, provided that such additional information is kept separately and is subject to technical and organisational measures to ensure that the personal data are not attributed to an identified or identifiable natural person.*



Pseudonymization

- Pseudonymization replaces identifying fields with artificial identifiers (tokens).
- Characteristics:
 - Reversible with additional information
 - **Data remain personal data**
 - Reduces impact of breaches (i.e., not every actor who sees the pseudonymized dataset can immediately identify the person behind it)
 - Supports **privacy-by-design** strategies
- Pseudonymization **reduces risk** but does not eliminate regulatory obligations.



Anonymization vs Pseudonymization

Anonymization

- Goal: remove identifiability
- Reversible? **No, if effective**
- Personal data? **No, if effective**
- Main benefit: data may fall outside GDPR

Pseudonymization

- Goal: reduce exposure
- Reversible? **Yes, with additional information**
- Personal data? **Yes**
- Main benefit: lower risk, support privacy-by-design strategies



Comparison of Protection Mechanisms

Mechanism	Acts on	Personal Data?	Main Purpose
Access control	Who can access/use data	Yes	Prevent unauthorized access
Encryption	Data representation	Yes	Protect confidentiality
Pseudonymization	Identifiers	Yes	Reduce exposure
Anonymization	Identifiability	No (if effective)	Remove identifiability



Roadmap – From Concepts to National Security

1. Information Protection

- Privacy – Data Protection – Secrecy

2. Data Protection Framework

- GDPR Principles – Accountability – Data Breach

3. Protection Mechanisms

- Access Control – Encryption – Anonymization – Pseudoanonymization
– Logging

4. Secrecy & National Defense

- Classification – Need-to-Know – Governance



Secrecy as Institutional Protection

- Secrecy protects information whose disclosure would harm collective interests.
- It typically concerns:
 - National security
 - Strategic infrastructure
 - Military operations
 - Intelligence activities
 - or other high-impact state functions
- Unlike privacy, secrecy protects:
 - Institutions, missions, and the State
 - Not individual personal rights

📌 Secrecy is a governance mechanism for managing high-impact risk.



Classification Levels in Italy

The Italian law provides for four classifications of secrecy, defined as National, to which correspond increasing levels of information protection:

- **RISERVATO** (R), slight damage to the interests of the Republic;
- **RISERVATISSIMO** (RR), damage to the interests of the Republic;
- **SEGRETO** (S), serious damage to the interests of the Republic;
- **SEGRETISSIMO** (SS), exceptionally serious damage to the interests of the Republic.

[Legge 3 agosto 2007, n. 124

Decreto del Presidente del Consiglio dei Ministri 12 giugno 2009, n. 7]



Need-to-Know Principle



Even with authorization or clearance, access should be limited to information strictly necessary for a specific role or mission.

- **Clearance is not unlimited access**
- **Distribution is constrained by operational necessity**
- The goal is to reduce exposure and limit damage if compromise occurs

In secrecy regimes, authorization and need-to-know work together to control dissemination.



International Classification Mapping

Italia	USA	UK	Francia
SEGRETISSIMO	TOP SECRET	TOP SECRET	TRÈS SECRET DÈFENSE
SEGRETO	SECRET	SECRET	SECRET DÈFENSE
RISERVATISSIMO	CONFIDENTIAL	NO NATIONAL EQUIVALENT	CONFIDENTIAL DÈFENSE
RISERVATO	NO NATIONAL EQUIVALENT	OFFICIAL SENSITIVE	NO NATIONAL EQUIVALENT



International Classification Mapping

NATO	UE
COSMIC TOP SECRET	TRÈS SECRET EU / EU TOP SECRET
NATO SECRET	SECRET UE / EU SECRET
NATO CONFIDENTIAL	CONFIDENTIAL UE / EU CONFIDENTIAL
NATO RESTRICTED	RESTREINT UE / EU RESTRICTED

N.B.: The wording “NATO Unclassified” appearing on non-classified NATO documents is **not** a security classification, but it still entails a minimum level of protection (**non-disclosure**).



Secrecy vs Confidentiality

Confidentiality (Security Property)

- Part of CIA triad
- Protects data from unauthorized access
- Implemented via technical mechanisms (e.g. encryption, access control)
- Applies to many systems

Secrecy (Institutional Regime)

- Legal & organizational framework
- Protects sensitive state interests
- Implemented via classification & handling rules
- Applies to specific categories of information



Secrecy and National Defense

Secrecy supports national defense by:

- Protecting strategic capabilities
 - if an adversary knows too much about military systems, plans, vulnerabilities, logistics, the effectiveness of those capabilities may be reduced
- Preventing adversarial intelligence gathering
 - information denied to the adversary is often as important as information possessed by one's own side
- Reducing systemic vulnerability
 - large-scale disclosure may expose exploitable weaknesses
- **However:** Excessive secrecy reduce transparency
- Democratic systems require balance



Information Protection – Three Dimensions

Concept	What is protected	Who defines the rules
Privacy	The individual's private sphere	Fundamental rights
Data Protection	Processing of personal data	Legal & Governance frameworks
Secrecy	Sensitive information of organizations or states	Institutional authority



Suggested reading

